

多租户数据隔离安全策略

SaaS 知识平台租户隔离与数据安全设计

作者：信息安全与架构组

日期：2026-07-30

文档编号：SEC-2026-003

目 录

第1章 隔离模型选型

第2章 行级隔离实现机制

第3章 密钥与加密管理

第4章 审计与合规

第1章 隔离模型选型

多租户数据隔离是 SaaS 化知识平台的安全基石。常见的隔离模型包括共享数据库共享 schema、共享数据库独立 schema、独立数据库三种，各自在隔离强度与运维成本上存在权衡。

本平台采用共享数据库共享 schema 为主模型，通过租户标识字段实现行级隔离，并辅以独立 schema 为高安全租户提供增强隔离。这种混合模型在资源利用率与安全灵活性之间取得了平衡。

选型决策应综合考虑租户规模分布、合规要求、运维复杂度与成本预算，避免一刀切地采用最高隔离级别而带来不必要的资源浪费。

第2章 行级隔离实现机制

行级隔离在数据库层通过租户标识列与查询拦截器实现，所有 SQL 在执行前自动注入租户过滤条件，从机制上杜绝跨租户数据访问。应用层则在请求上下文中传递租户身份，确保整条调用链路租户一致。

在向量检索层，为每个租户维护独立的分区或独立索引，查询时按租户路由，避免跨租户检索带来的性能与安全风险。对超大租户采用独立索引以保障检索性能。

所有隔离逻辑需通过自动化测试覆盖，包含正向用例与越权访问用例，确保任何代码变更不会破坏隔离边界。

第3章 密钥与加密管理

静态数据采用透明数据加密(TDE)保护，密钥由专用密钥管理服务(KMS)托管，并按租户分配独立数据加密密钥(DEK)，由主密钥(KEK)包装存储，实现密钥层级隔离。

传输链路全程启用 TLS 1.3，内部服务间通信采用 mTLS 双向认证，防止中间人攻击。敏感字段如个人身份信息额外采用应用层加密，即使数据库被拖库也无法还原明文。

密钥轮换遵循最小周期策略，主密钥每年轮换，数据加密密钥按需轮换，轮换过程对业务透明，不影响在线服务。

第4章 审计与合规

建立全量操作审计日志，记录所有数据访问行为，包括访问者、租户、对象、操作类型与时间戳，日志独立存储并防篡改，支持按租户维度检索与导出，满足合规审计要求。

定期开展租户隔离专项安全评估，通过渗透测试与代码审计验证隔离有效性，对发现的隔离缺陷建立闭环修复流程。

结合等级保护与个人信息保护法要求，形成数据隔离合规矩阵，逐项对标落实，确保平台满足多行业客户的合规准入门槛。